국방 사이버보안 위험관리 지시

[시행 2025. 2. 28.] [국방부기타 제2025-8호, 2025. 2. 28., 일부개정]

국방부(사이버전자기정책과), 02-748-6756

제1장 총칙

제1조(목적) 이 지시는「국방정보화 기반조성 및 국방정보자원관리에 관한 법률」제21조의2에 따라 무기체계 및 전력지원체계의 사이버보안 위험을 수명주기 관점에서 관리하기 위해 국방 사이버보안 위험관리의 추진, 운영, 관리 등에 필요한 사항을 규정함을 목적으로 한다.

제2조(정의) 이 지시에서 사용하는 용어의 정의는 다음 각 호와 같다.

1. "국방정보"(이하 "정보"라 한다)란 국방을 위하여 광(光) 또는 전자적 방식으로 처리하여 부호・문자・음성・음향 및 영상 등으로 표현한 모든 종류의 자료 또는 지식을 말한다.
2. "국방정보시스템"이란 국방정보의 수집・가공・저장・검색・송신・수신 및 그 활용과 관련되는 기기와 소프트웨어의 조직화된 체계를 말한다. 국방정보시스템의 세부 분류는「국방 정보화업무 훈령」제5조에 따른다.
3. "무기체계"란 유도무기・항공기・함정 등 전장(戰場)에서 전투력을 발휘하기 위한 무기와 이를 운영하는데 필요한 장비・부품・시설・소프트웨어 등 제반요소를 통합한 것을 말한다. 무기체계의 분류는「국방전력발전업무훈령」별표 4에 따른다.
4. "전력지원체계"란 무기체계 외의 장비・부품・시설・소프트웨어 및 그 밖의 물품 등 제반요소를 말한다. 전력지원체계의 분류는「국방전력발전업무훈령」별표 5에 따른다.
5. "시스템" 또는 "체계"란 국방정보시스템 및 내장형 소프트웨어를 가지고 있는 무기체계와 전력지원체계를 말한다.
6. "기밀성"이란 허용되지 않은 접근이나 공개로부터 정보를 보호하는 것을 말한다.
7. "무결성"이란 정보가 부적절하게 훼손・멸실・변경・위조되지 않도록 보호하는 것을 말한다.
8. "가용성"이란 신뢰할 수 있는 사용자가 적시에 정보에 접근하여 정보를 사용할 수 있도록 보장하는 것을 말한다.
9. "사이버보안"이란 정보 및 시스템을 사이버 위협으로부터 보호하며 피해가 발생한 경우 이를 복구함으로써 정보의 기밀성・무결성・가용성을 보장하는 것을 말한다.
10. "사이버보안 위험"(이하 "위험"이라 한다)이란 잠재적인 상황이나 사건에 의해 정보의 기밀성・무결성・가용성이 훼손되어 발생할 수 있는 위협의 영향과 그 발생 가능성의 정도를 말한다.
11. "국방 사이버보안 위험관리"(이하 "위험관리"라 한다)란 무기체계 및 전력지원체계의 소요제기부터 획득, 운용, 유지, 폐기에 이르는 전 수명주기 관점에서 사이버보안 위험을 예방, 평가하고 대응, 완화하는 등의 방법을 통하여 대상 무기체계 및 전력지원체계의 위험을 관리하기 위한 체계적 절차를 말한다.

12. "국방 사이버보안 위험관리 제도"(이하 "위험관리 제도"라 한다)란 군에서 위험관리를 수행하기 위한 필요한 조직과 절차, 규정, 기준 등의 체계를 말하며, 영문 약칭으로 K-RMF(Korea-Risk Management Framework)라고 한다.
13. "대상체계"란 위험관리가 적용되는 시스템을 말한다.
14. "보안통제항목"이란 조직이 해당 정보 및 시스템의 사이버보안을 위해 선정한 기술적·관리적 안전조치 또는 대응조치를 말한다.
15. "보안영향 수준"이란 정보의 유형 또는 속성에 따라 해당 정보 및 시스템의 기밀성·무결성·가용성에 영향을 미치는 수준을 말한다.
16. "기준선"이란 시스템 분류 결과에 따라 기본으로 선정되는 보안통제항목의 목록을 말한다.
17. "소요제기기관"이란「국방전력발전업무훈령」제10조제1항에 따른 기관으로서 무기체계 및 전력지원체계의 소요를 제기하는 기관을 말한다.
18. "사업관리기관"이란 사업의 계약부터 종결 시까지 사업계약, 일정관리, 형상관리, 품질관리 및 개발시험평가 등 관련된 제반 업무를 관리하는 주된 기관을 말한다.
19. "체계운영기관"이란 무기체계 및 전력지원체계를 운용하는 기관으로 운영·유지 단계에서 사이버보안의 확보를 위해 관련 조직, 인력, 자산의 운영 및 관리 임무를 수행하는 기관을 말한다.
20. "인가권자"란 대상체계를 통해 수행하고자 하는 임무(업무)를 보유한 조직 내의 장성급 부서(부대)장으로서 대상체계에 대한 운용 여부를 결정하며 운용단계에서 대상체계의 위험관리가 적절히 수행될 수 있도록 감독·승인의 책임이 있는 자를 말한다.

제3조(기본원칙) 이 지시에 따른 위험관리 제도는 다음 각 호의 원칙을 고려하여 운영되어야 한다.

1. 체계적이고 효율적인 위험관리를 위하여 유사하거나 중복되는 절차 등을 이 지시에 점진적으로 통합하여 운영한다.
2. 위험관리 업무의 타당성 및 신뢰성을 보장하기 위하여 수행 조직 및 인력의 전문성을 제고한다.
3. 위험관리 업무는 관계기관 간 투명하고 원활한 의사소통 및 협의를 통해 합리적인 의사결정이 이뤄질 수 있도록 운영한다.

제4조(적용범위) ① 이 지시는 다음 각 호의 부대 및 기관(이하 "기관"이라 한다)에 적용한다.

1. 국방부 본부(이하 "국방부"라 한다)
2. 합동참모본부(이하 "합참"이라 한다)
3. 육·해·공군 및 해병대(이하 "각군"이라 한다)
4. 방위사업청(이하 "방사청"이라 한다)
5. 국군방첩사령부(이하 "방첩사"라 한다)
6. 사이버작전사령부(이하 "사이버사"라 한다)
7. 국군지휘통신사령부(이하 "통신사"라 한다)
8. 국방전산정보원(이하 "국전원"이라 한다)

9. 국방부 직할부대 및 기관(이하 "국직기관"이라 한다)
10. 국방과학연구소(이하 "국과연"이라 한다)
11. 국방기술품질원(이하 "기품원"이라 한다)
12. 그 밖에 이 지시에서 정하는 업무와 관련이 있는 기관

② 이 지시에 따른 위험관리 적용 대상은 국방정보시스템 및 내장형 소프트웨어(Embedded Software)를 가지고 있는 무기체계와 전력지원체계로서 각 대상체계의 평가범위는 위험관리의 효율적 수행을 고려하여 인가권자가 조정할 수 있다. 다만, 다음 각 호의 체계는 제외한다.

1.「국방상호운용성 관리지시」별표 5의 사업특성분류에 따른 0형. 다만, 대상체계의 일부가 정보시스템으로 구성되거나 정보통신기술을 통제에 활용하는 등 사이버공격으로부터 보호의 필요성이 높은 경우에는 위험관리를 적용할 수 있다.
2. 사이버보안의 관점에서 중요도가 현저히 떨어져 위험관리의 필요성이 없다고 판단되는 체계

③ 대상체계에 대한 적용 여부의 판단이 필요한 경우 국방부(지능정보화정책관)에서 결정할 수 있다.

④ 이 지시에서 규정하는 사항을 다른 훈령, 지시 등에서 다르게 규정하는 경우에는 이 지시를 우선하여 적용한다.

⑤ 이 지시에 규정되지 아니한 사항은「국방보안업무훈령」및「국방사이버안보 훈령」,「국방 정보보안시스템 업무 훈령」에서 정하는 바에 따른다.

제2장 위험관리 제도의 수립 및 운영

제5조(위험관리 제도의 수립) ① 국방부(지능정보화정책관)는 위험관리 제도를 수립・운영하기 위해 다음 각 호의 사항을 결정하여야 한다.

1. 정보유형 및 보안영향 수준의 기준
2. 보안분류 방법의 개발 및 최신화
3. 보안통제항목 기준선의 설정 및 최신화
4. 그 밖에 위험관리 운영 및 개선을 위해 필요한 사항

② 방첩사는 제1항에 따른 사항을 구체화하여 위험관리 적용에 필요한 각종 가이드, 지침서 등의 문서를 작성하고, 작성된 문서는 국방부(지능정보화정책관) 및 국방정보본부의 검토 후 배포하는 것을 원칙으로 한다.

③ 합참, 각군 등 제4조에 따른 기관은 위험관리 업무수행을 위한 자체 계획을 수립하고 관련 지침을 보완하여야 한다.

제6조(위험관리 제도의 운영) ① 위험관리는 대상체계의 소요제기부터 획득, 운영유지 및 폐기에 이르기까지 전 수명주기에 걸쳐 적용한다. 다만, 국방부에서 필요하다고 판단하는 경우 특정 대상체계에 대한 위험관리는 운영유지 단계에서부터 적용할 수 있다.

② 위험관리의 절차는 다음 각 호와 같다.

1. 1단계(시스템 보안분류): 시스템 및 해당 시스템에서 생산, 유통하는 정보의 유형에 따라 대상체계를 기밀성, 무결성, 가용성 수준 또는 기타 특정 유형으로 분류하는 단계를 말한다.
2. 2단계(보안통제항목 선정): 시스템 보안분류 결과를 토대로 보안계획서 작성을 통해 대상체계에 구현해야 하는 보안통제항목을 선정하고 구현계획을 수립・구체화하는 단계를 말한다.
3. 3단계(보안통제항목 구현): 작성한 보안계획서에 따라 선정된 보안통제항목을 소프트웨어 개발, 장비 구매, 운영절차 및 운용환경 마련 등의 방법으로 해당 대상체계에 보안요구사항을 구현하는 단계를 말한다.
4. 4단계(보안평가): 보안통제항목이 보안계획서에 따라 적절히 구현되었는지 여부를 평가하고 위험판단을 수행하는 단계를 말한다.
5. 5단계(시스템 인가): 보안평가를 통해 도출한 결과에 따라 해당 대상체계의 위험 수준을 결정하고 운용 가능 여부를 결정하는 단계를 말한다.
6. 6단계(보안통제항목 모니터링): 운용인가서, 보안계획서, 후속조치계획서 등에 따라 대상체계의 폐기 전까지 위험을 지속 관리하는 단계를 말한다.

③ 사이버사는 위험관리 이행 과정에서 필요한 경우 대상체계의 취약점을 찾아 침투 가능성을 실증적으로 검토하는 모의침투를 수행할 수 있다.

제7조(위험관리 운영성과 분석) ① 국방부(지능정보화정책관)는 매년 말 해당연도의 위험관리 운영성과를 분석하여야 한다.

② 국방부, 합참, 각군 등 기관은 제1항에 따른 분석결과를 반영해 위험관리 정책을 개선하여야 한다.

③ 국방부, 합참, 각군 등 기관은 분석결과 성과가 우수하거나 위험관리 적용 및 발전에 공적이 있는 기관 또는 개인에게 표창수여, 포상금 지급, 특별휴가, 인사관리 등의 우대조치를 할 수 있다.

제8조(K-RMF 운영시스템) ① 방첩사는 효율적인 위험관리를 위해 K-RMF 운영시스템을 구축・운용할 수 있다.

② 이 지시의 적용을 받는 모든 기관은 K-RMF 운영시스템을 통해 위험관리 업무를 수행하고 생산한 자료를 K-RMF 운영시스템에 등록하여야 한다.

③ 방첩사는 K-RMF 운영시스템의 안정적 운용 및 기능 고도화를 위해 매년 말 관계기관 등 사용자 의견을 수렴하고 국방부와 협의하여 개선이 필요한 사항을 시스템에 반영하여야 한다.

제9조(전문성 강화) ① 국방부(지능정보화정책관)는 관계기관과 협의하여 위험관리 수행인력에 요구되는 자격 요건 및 기준을 수립할 수 있다.

② 국방부, 합참, 방사청, 각군 등 기관은 위험관리 전문성을 높이기 위하여 필요한 교육훈련을 시행하는 등 전문인력을 양성 및 관리하여야 한다.

③ 국방부, 합참, 방사청, 각군 등 기관은 제2항에 따른 교육훈련을 방첩사에 요청하거나 국내외 전문기관에 위탁할 수 있으며 필요한 경우 국외 연수 등을 실시할 수 있다.

④ 방첩사는 제3항에 따른 교육훈련을 지원하기 위해 위험관리 전문인력을 양성 및 관리하여야 한다.

제3장 위험관리 정책의 추진체계

제10조(국방 사이버보안 위험관리 위원회) ① 국방 사이버보안 위험관리에 관한 다음 각 호의 사항을 심의・의결하기 위하여 국방 사이버보안 위험관리 위원회(이하 "위원회"라 한다)를 둔다.

1. 이 지시의 개정에 관한 사항
2. 위험관리 운영 관련 기관 간 임무의 조정에 관한 사항
3. 위험관리 운영 및 개선에 관한 중요사항 검토 및 승인
4. 제11조에 따른 실무위원회에서 상정한 대상체계의 운영인가 검토 및 결정
5. 그 밖에 위원장이 위험관리 운영 및 개선 등에 필요하다고 판단하는 사항

② 위원회의 위원장은 국방부 기획조정실장이 되고 위원은 다음 각 호의 사람이 된다.

1. 국방부 지능정보화정책관, 전력정책국장, 군수관리관
2. 합참 전력기획부장, 지휘통신부장
3. 육・해・공군 정보화기획참모부장, 해병대 지휘통신참모처장
4. 방위사업청 기획조정관
5. 국방정보본부 정보기획부장
6. 국군방첩사령부 1처장
7. 사이버작전사령관
8. 그 밖에 안건에 따라 위원장이 지명하는 자

③ 위원회 업무를 담당하기 위해 위원회에 간사 1인을 두며 간사는 국방부 지능정보화기획담당관이 된다.

④ 위원회는 위원 과반수의 출석으로 개회하고 출석위원 과반수의 찬성으로 의결한다.

⑤ 위원이 위원회에 참석할 수 없는 경우 사전에 위원장의 승인을 받아 지명한 대리인을 참석하도록 할 수 있으며 대리인의 의사표시는 위원이 행한 것으로 본다.

⑥ 위원장은 필요하다고 판단하는 경우 해당 안건과 관련된 부서 또는 기관의 장을 지명하여 배석시킬 수 있다.

⑦ 간사는 안건에 대한 충분한 검토가 이루어질 수 있도록 위원회 개최 전에 안건을 각 위원에게 배포하여야 한다.

⑧ 위원장은 위원회의 개최가 어렵거나 서면으로 심의하는 것이 효과적이라고 판단하는 경우 서면 심의로 대체할 수 있다.

⑨ 이 지시에서 정한 사항 이외에 위원회 운영에 필요한 사항은 위원장이 정한다.

제11조(국방 사이버보안 위험관리 실무위원회) ① 국방 사이버보안 위험관리 실무에 관한 다음 각 호의 사항을 심의・의결하고 제10조에 따른 위원회에 상정되는 안건을 협의・조정하기 위하여 실무위원회를 둔다.

1. 위원회로부터 위임받은 사항
2. 위험관리 정책의 수립 및 변경

3. 주요 대상체계의 운영인가 여부
4. 외국군 및 국방부 외 타기관 체계의 연동과 관련된 위험관리 적용 여부
5. 보안통제항목 평가 및 운영인가 위임에 관한 사항
6. 위험관리와 관련된 기관의 업무 조정・협의
7. 보안평가 결과에 대한 이견 조정
8. 그 밖에 위원장이 필요하다고 인정하는 사항

② 실무위원회의 위원장은 국방부 지능정보화정책관이 되며 위원은 다음 각 호와 같다.

1. 국방부 지능정보화기획담당관, 전력정책과장, 군수기획과장
2. 합참 전력기획과장, 지휘통신기획과장
3. 육・해・공군 사이버정책과장, 해병대 지휘통신계획과장
4. 방위사업청 정보화데이터담당관
5. 국방정보본부 보안암호정책과장
6. 국군방첩사령부 사이버보안실장
7. 사이버작전사령부 제3작전단장
8. 그 밖에 위원장이 지명하는 자

③ 실무위원회의 운영을 보조하기 위해 실무위원회에 간사 1명을 두며 간사는 국방부 지능정보화기획담당관실 업무담당이 된다.

④ 실무위원회의 운영에 관한 사항은 제10조제4항부터 제9항까지를 준용한다.

제12조(공통 임무) 국방부, 합참, 각군 등 기관은 공통적으로 다음 각 호의 임무를 수행한다.

1. 기관별 위험관리 적용 현황 최신화 및 업무 수행 관리・감독
2. 기관별 위험관리 절차 세부 적용방안 수립 및 발전
3. 보안통제항목 추가, 삭제, 수정 등에 관한 건의 및 정보공유
4. 기관별 보안통제항목 구현지침 수립 및 발전
5. 기관 별 공통 보안통제항목 지정 및 관리

제13조(국방부 본부) 국방부 본부는 다음 각 호의 임무를 수행한다.

1. 위험관리 정책의 수립
2. 위험관리 업무의 총괄, 조정 및 통제
3. 위험관리 제도 발전
4. 위험관리 운영 인력 양성을 위한 정책의 수립

제14조(합동참모본부) 합참은 다음 각 호의 임무를 수행한다.

1. 무기체계 소요제기기관 및 소요결정기관으로서 위험관리 업무
2. 무기체계 보호에 필요한 위험관리 업무

제15조(각군) 각군은 다음 각 호의 임무를 수행한다.

1. 소관 대상체계 소요제기기관, 사업관리기관, 체계운영기관으로서 위험관리 업무
2. 예하부대(서) 위험관리 업무 수행 관리・감독
3. 각군 차원의 위험관리 전문인력 관리 및 교육, 관련 기술 육성

제16조(방위사업청) 방사청은 다음 각 호의 임무를 수행한다.

1. 사업관리기관으로서 사업관리 기간 동안의 위험관리 업무 수행
2. 방위력개선사업의 위험관리 적용 정착 및 제도 발전

제17조(국군방첩사령부) 방첩사는 다음 각 호의 임무를 수행한다.

1. 보안평가 업무 총괄 및 수행
2. 시스템 보안분류 및 보안통제항목 선정 적절성 검토
3. 보안계획서 적절성 검토
4. 위험관리 정책 수립 및 관련 법규 제・개정 지원
5. 위험관리 표준문서・가이드・보안통제항목의 개발 및 관리
6. 위험관리 전문화교육・자격관리 제도 개발, 시행 및 관리
7. K-RMF 운영시스템의 구축・운용
8. 위험관리 전문인력의 양성 및 관리

제18조(사이버작전사령부) 사이버사는 다음 각 호의 임무를 수행한다.

1. 시스템 대상 위협모델링 수행
2. 사이버작전 차원의 모의침투 수행
3. 네트워크별 사이버 위협 정보 분석 및 제공

제19조(국군지휘통신사령부) 통신사는 다음 각 호의 임무를 수행한다.

1. 전력지원체계 소요제기기관 및 사업관리기관, 전장관리 및 전력지원 체계운영기관으로서 위험관리 업무 수행
2. 지휘통신 분야 위험관리 정착 및 관련 기술 육성

제20조(국방전산정보원) 국전원은 다음 각 호의 임무를 수행한다.

1. 국방부와 그 소속기관의 정보화업무 지원 및 국방자원관리 정보체계의 구축・운영에 관한 위험관리 업무 수행
2. 전군 지원 국방정보화사업 분야 위험관리 정착 및 관련 기술 육성

제21조(국방과학연구소) 국과연은 다음 각 호의 임무를 수행한다.

1. 무기체계 연구개발 추진 시 연구개발주관기관으로서 위험관리 적용
2. 최신 보안기술을 활용한 위험관리 보안통제항목 구현방법 연구

제22조(국방기술품질원) 기품원은 다음 각 호의 임무를 수행한다.

1. 연구개발사업의 위험관리 효율화를 위한 정책 및 제도 발전 지원
2. 업체 주관 연구개발의 보안계획서 작성, 보안통제항목 구현 점검 지원
3. 업체 주관 연구개발사업의 효율적인 위험관리 적용을 위한 기법 발전

제4장 무기체계 위험관리

제1절 소요 단계

제23조(시스템 보안분류) ① 소요제기기관은 무기체계 소요를 제기하는 경우 대상체계에 포함된 정보유형을 식별하고 식별된 정보의 유형별 보안영향 수준을 판단해 별표 1의 기준에 따라 시스템 보안분류를 수행하여야 한다. 시스템 보안분류에 관하여 필요한 사항은 "시스템 보안분류 가이드"를 참고한다.

② 소요제기기관은 부대 보안심사위원회를 통해 시스템 보안분류를 결정하며 필요한 경우 방첩사에 시스템 보안분류 결과를 포함한 소요제기서의 보안대책 항목에 대한 검토를 요청할 수 있다.

③ 방첩사는 제2항에 따른 시스템 보안분류 결과의 검토를 요청받은 경우 14일 이내에 해당 시스템 보안분류가 적절한지 여부를 판단해 회신하여야 한다.

④ 소요제기기관은 대상체계에 대한 인가권자를 결정하여 해당 내용을 제1항에 따라 수행한 시스템 보안분류의 결과와 함께 소요제기서에 기재하여야 한다.

⑤ 소요제기기관은 대상체계에 대한 모의침투 필요성을 검토하여 수행 여부를 소요제기서에 포함한다. 다만,「국방전력발전업무훈령」별표 4의 지휘통제체계를 대상으로 하는 때에는 반드시 모의침투를 수행하여야 한다.

⑥ 제5항에도 불구하고, 상호운용성 평가를 통한 사이버전 대비능력을 평가하는 경우에는 모의침투 대신 그 결과를 활용한다.

⑦ 소요제기기관은 제1항부터 제5항에 따른 시스템 보안분류 결과 등을 별지 제1호서식에 따른 시스템 보안분류 결과서에 기재하고 이를 소요제기서에 첨부하여 합참(전력부)에 제출하여야 한다.

제24조(시스템 보안분류의 결정) ① 합참(전력부)은 제23조에 따라 제출된 소요제기서를 검토하고 시스템 보안분류 결과, 모의침투 수행 여부, 인가권자 등을「국방전력발전업무훈령」제18조에 따른 전력소요서에 반영하여야 한다.

② 합참(전력부)은 전력소요 결정 시 시스템 보안분류와 모의침투 수행 여부 및 인가권자를 확정한다.

③ 합참(전력부)은 제2항에 따른 전력소요의 결정 시 필요하다고 판단하는 경우 소요제기기관, 방첩사, 사이버사, 체계운영기관 및 방사청 등 관계기관의 의견을 참고할 수 있다.

제2절 획득 단계

제25조(사이버보안조정회의) ① 방사청은 무기체계 획득 단계에서 위험관리를 적용하는 경우 다음 각 호의 사항에 관한 이견을 조율하기 위해 사이버보안조정회의를 구성・운영할 수 있다.

1. 보안통제항목의 선정
2. 보안통제항목의 구현
3. 보안통제항목 책임기관의 지정
4. 보안평가 결과에 따른 후속조치 방안의 결정
5. 보안평가 결과 등에 대한 이견 조정
6. 그 밖에 각 기관 간 이견 조정 등 위험관리 적용을 위해 의장이 필요하다고 인정하는 사항

② 사이버보안조정회의의 의장은 통합사업관리팀장으로 한다.

③ 사이버보안조정회의는 대상체계의 획득 및 평가, 운용과 관련된 각 기관의 담당자로 구성할 수 있으며, 필요시 외부전문가 등을 포함하여 구성할 수 있다.

④ 의장은 사이버보안조정회의의 원활한 운영을 위해 필요하다고 판단하는 경우 기타 관계자의 참여를 요청할 수 있다.

제26조(탐색개발 단계 보안통제항목 선정) ① 방사청은 무기체계 탐색개발을 수행하는 경우 기술적 보안통제항목을 선정하고, 소요제기기관이 선정한 관리적 보안통제항목을 종합한 후 사이버보안조정회의를 통해 관계기관의 의견을 수렴하여 보안통제항목을 결정하고 그 결과를 관계기관에 통보하여야 한다.

② 사이버사는 제1항에 따른 탐색개발의 완료 전까지 대상체계에 대한 위협모델링 결과를 작성하여 방첩사에 제공하여야 한다.

③ 방첩사는 제2항에 따른 위협모델링 결과를 참고하여 제1항에 따라 선정된 보안통제항목을 검토하고 그 결과를 20일 이내에 합참과 방사청에 회신하여야 한다.

④ 연구개발주관기관은 구현해야 할 보안통제항목의 대상체계 작전운용성능에 대한 영향성 검토결과와 자체 검증결과를 작성하여 그 결과를 20일 이내에 소요제기기관, 합참, 방사청에 회신하여야 한다.

⑤ 방사청은 제3항 및 제4항에 따른 검토결과를 참고하여 보안통제항목을 조정할 수 있으며 이 경우 그 결과를 합참과 방첩사에 통보하여야 한다. 다만, 방첩사의 검토결과와 다르게 보안통제항목을 조정하는 경우에는 그 사유를 명시하여야 한다.

⑥ 방사청은 제5항에 따른 검토 결과를 탐색개발결과에 반영하여야 한다.

⑦ 방사청은 제5항에 따라 결정된 사항이 개발 간 구현될 수 있도록 "「국방 사이버보안 위험관리 지시」 규정을 고려하여 추진" 등으로 포괄적 수준으로 제안요청서(Request for Proposal, RFP)에 반영하여야 한다.

⑧ 탐색개발을 수행하지 않는 경우 방사청은 체계개발 시에 보안통제항목 선정을 수행한다.

제27조(체계개발 단계 보안계획서 작성) ① 방사청은 체계개발 단계에 보안계획서 작성에 대한 총괄 임무를 수행하여 연구개발주관기관과 소요제기기관이 작성한 보안계획서를 종합하고 방첩사의 검토를 통해 보완하여 상세설계검토(Critical Design Review, CDR)에서 확정한다.

② 연구개발주관기관은 기술적으로 구현이 필요한 보안통제항목에 대한 구현계획을 체계개발 사업 진행 과정에서 구체화하여 별지 제2호서식에 따른 보안계획서에 작성하여야 한다.

③ 소요제기기관은 관리적으로 구현이 필요한 보안통제항목에 대한 구현계획을 구체화하여 별지 제2호서식에 따른 보안계획서에 작성하여야 한다.

④ 소요제기기관은 제3항에 따른 보안계획서 작성을 위하여 대상체계의 체계운영기관에 관련 자료 제출 등 협조를 요청할 수 있다.

⑤ 방사청은 제2항 및 제3항에 따라 작성된 보안계획서를 종합하여 방첩사에 검토를 의뢰하여야 한다.

⑥ 방첩사는 제5항에 따른 보안계획서를 검토한 결과를 방사청에 20일 이내에 회신하고, 소요제기기관에 통보하여야 한다.

⑦ 방사청은 제6항에 따른 방첩사의 검토 결과와 해당 사업의 성격을 고려하여 보안계획서를 보완하고 기술적 구현이 필요한 사항을 체계 설계 문서에 반영하여야 한다.

⑧ 방사청은 제7항에 따라 보완이 완료된 보안계획서를 상세설계검토(CDR)에 반영하여 확정한다.

제28조(보안통제항목 구현) ① 연구개발주관기관 및 체계운영기관은 제27조제8항을 통해 확정된 보안계획서에 따라 소관 보안통제항목을 구현하여야 한다.

② 연구개발주관기관과 소요제기기관은 제1항에 따른 보안통제항목 구현 과정에서 대상체계의 설계 변경 또는 기타 사유로 인해 보안통제항목을 구현하기 어려운 경우 방사청에 사이버보안조정회의를 통한 조정을 요청할 수 있으며, 방사청은 회의결과에 따라 해당 항목을 조정하고 그 결과 및 사유를 보안계획서에 반영하여야 한다.

③ 방사청은 신속하고 효율적인 보안평가를 위해 구현 단계에서 방첩사와 협의된 항목에 대해 기품원과 국과연을 통해 자체 점검을 수행할 수 있으며, 보안평가 시 활용토록 할 수 있다.

제29조(무기체계 보안평가 일정 수립) ① 무기체계 보안평가는 운용시험평가 기간 중에 실시한다.

② 합참은 제1항에 따른 보안평가를 수행할 수 있도록 시험평가기본계획 수립 시 보안평가 일정을 고려해야 한다.

③ 제1항에 따른 보안평가의 기간은 최대 30일을 초과할 수 없으며 방첩사에 귀책이 없는 중대한 사유로 평가가 지연되는 기간은 포함하지 않는다.

제30조(무기체계 보안평가) ① 방사청은 제29조제1항에 따른 보안평가 예정일(현장평가일 기준) 60일 전까지 최신화된 보안계획서를 방첩사에 제출하고 보안평가를 의뢰하여야 한다.

② 방첩사는 제1항에 따른 의뢰를 받은 경우 30일 이내에 별지 제3호서식에 따른 보안평가 계획서(안)을 작성하여야 한다. 대상체계가 전력소요서상 모의침투 대상에 해당하는 경우에는 사이버사로부터 모의침투 계획을 제공받아 보안평가 계획서(안)에 반영하여야 한다.

③ 방사청은 제2항에 따른 보안평가 계획서(안)을 검토하여 의견을 제시할 수 있다. 다만, 보안평가 계획서(안)에 이견이 있는 경우 사이버보안조정회의를 통해 보안평가 계획서(안)을 검토할 수 있다.

④ 방첩사는 제3항에 따른 검토결과를 참고하여 보안평가 계획서를 확정한다.

⑤ 방첩사는 보안평가 계획서에 따라 보안통제항목의 평가를 수행한다. 제2항에 따라 보안평가 계획서에 모의침투 계획이 포함된 경우 사이버사는 모의침투를 수행하여야 한다.

⑥ 방첩사는 제5항에 따른 보안통제항목 평가 결과를 바탕으로 보안평가결과서를 작성하여 보안평가 종료일로부터 20일 이내에 방사청에 회신하여야 한다. 모의침투가 수행된 때에는 그 결과를 함께 반영하여야 한다.

⑦ 방첩사는 보안평가를 위해 필요한 경우 방사청 등 제4조의 관련 기관에 관련 자료의 구비 또는 제공을 요청할 수 있다.

⑧ 제3조제1호에도 불구하고, 방첩사는 보안평가 수행 시 중복되는 항목의 활용 가능한 선행 평가결과가 있는 경우 활용한다.

⑨ 보안평가가 원활하게 수행될 수 있도록 방사청은 연구개발주관기관의 통제 및 평가 여건 보장 등, 소요제기기관은 부대 내 시험환경 및 체계 접근 등 필요한 사항을 지원하여야 한다.

제31조(보안평가 후속조치) ① 방사청은 제30조에 따른 보안평가 결과 미흡한 보안통제항목이 있는 때에는 사이버보안조정회의를 통해 다음 각 호에 따라 해당 보안통제항목의 후속조치방안 및 조치수행기관을 결정하여야 한다.

1. 단기조치: 연구개발주관기관의 사업범위로 사업기간 내 조치가 가능한 경우
2. 중장기조치: 연구개발주관기관의 사업범위 외 사항으로 소요제기기관이 사업 종료 이후 별도의 사업 또는 관리적 조치를 통해 조치가 필요한 경우

② 소요제기기관은 제1항에 따라 결정된 조치방안을 고려해 보안계획서에 반영하고 별지 제4호서식에 따른 후속조치 계획서를 작성하여야 한다.

③ 방사청은 연구개발주관기관을 통해 사업기간 내 단기조치를 완료하고 그 결과를 반영해 보안계획서를 수정하여 방첩사에 제출하여야 한다.

④ 방첩사는 보안계획서와 단기조치 완료 여부를 확인하여 보안평가결과서에 반영하고 이를 소요제기기관 및 방사청에 제출하여야 한다.

제32조(인가) ① 소요제기기관은 제31조에 따른 단기조치가 완료된 이후 보안계획서, 보안평가결과서, 후속조치계획서를 종합하여 인가권자에게 운용인가를 건의한다.

② 인가권자는 보안계획서와 후속조치계획서를 바탕으로 보안평가결과서에 따른 위험의 수용 여부를 판단하여 대상체계의 운용 여부를 다음 각 호에 따라 결정하고 별지 제5호서식에 따른 운용인가서를 발급하여야 한다.

1. 보안평가결과서에 따른 위험 수준이 '낮음' 또는 '매우 낮음'에 해당하는 경우: 인가
2. 보안평가결과서에 따른 위험 수준이 '보통'에 해당하는 경우: 인가 또는 조건부 인가
3. 보안평가결과서에 따른 위험 수준이 '높음' 또는 '매우 높음'인 경우: 조건부 인가

③ 보안평가결과서에 따른 위험 수준이 '높음' 또는 '매우 높음'임에도 불구하고 자체 판단이 어려운 경우 인가권자는 제11조에 따른 실무위원회에 인가 여부의 판단을 요청할 수 있다. 이 경우 실무위원회의 심의 결과에 따라 대상체계의 운용 여부를 최종 결정하여야 한다.

④ 인가권자는 운용 여부 결정 시 기간을 정할 필요가 있는 경우 별표 2에 따라 인가 기간을 정할 수 있다. 다만, 대상체계의 운용 여부가 '조건부 인가'인 경우 또는 타국 연동체계 및 C4I체계의 운용 여부를 결정하는 때에는 반드시 인가 기간을 정해야 한다.

제33조(양산된 무기체계에 대한 승인) ① 양산된 무기체계를 소요군에서 인수 시, 해당 체계운영기관의 담당 방첩부대에서 보안평가(현장점검)를 수행하고 제32조에 따른 본 체계 인가권자의 승인을 얻어야 한다.

② 체계운영기관은 양산된 무기체계의 운영환경 등을 고려해 본 체계의 보안계획서를 토대로 자체 보안계획서를 작성하여야 하며, 담당 방첩부대의 계획 검토를 의뢰한다.

③ 체계운영기관은 담당 방첩부대의 검토 결과와 부대 여건을 고려해 보안계획서를 수정하여 담당 방첩부대에 제출하고 양산된 무기체계의 보안평가(현장점검)를 의뢰하여야 한다.

④ 방첩부대는 제3항에 따라 제출된 자체 보안계획서에 따른 보안평가(현장점검) 결과를 본 체계 인가권자에게 제공하여야 한다.

⑤ 본 체계 인가권자는 보안계획서 및 제4항에 따른 보안평가(현장점검) 결과를 토대로 체계 운영을 위한 승인 여부를 결정하여야 한다.

제3절 운용 단계

제34조(모니터링) ① 체계운영기관은 보안계획서 및 후속조치 계획서에 따라 대상체계를 운영・관리하여야 하며, 인가권자는 이를 관리・감독하여야 한다.

② 체계운영기관은 제1항에 따른 대상체계 운영・관리 과정을 기록하여 관련 자료를 유지, 관리하고 제8조에 따른 K-RMF운영시스템에 등록하여야 한다.

③ 체계운영기관은 운영환경, 사이버 위협 등 주변 상황을 고려하여 보안계획서를 변경해야 하는 경우 보안계획서 변경안을 작성하고 담당 방첩부대에 검토를 의뢰하여야 한다.

④ 제3항에 따른 검토를 의뢰받은 담당 방첩부대는 보안계획서 변경안을 검토하여 그 결과를 체계운영기관에 회신하여야 한다.

⑤ 방첩사는 체계운영기관에서 보안계획서에 따라 대상체계를 관리하는지 여부를 확인・점검할 수 있다.

⑥ 방첩사는 제5항에 따른 대상체계 확인・점검 결과와「국방사이버안보 훈령」제46조에 의한 사이버보안 기관평가 결과 등을 통해 식별된 보안관리 수준, 체계 운영환경 및 사이버 위협 등 주변 변화를 고려해 필요하다고 판단하는 경우 대상체계에 대한 수시 보안평가를 실시할 수 있으며, 그 결과는 인가권자, 국방부(지능정보화정책관) 및 국방정보본부(정보기획부)에 제출하여야 한다.

⑦ 인가권자는 제6항에 따른 결과를 고려해 인가 여부를 재판단할 수 있다.

⑧ 체계운영기관은 제6항에 따른 수시 보안평가 결과 및 제7항에 따른 인가 여부의 재판단 결과를 반영해 보안계획서 또는 후속조치계획서를 최신화하여야 한다.

제35조(운영 중 평가 및 재인가) ① 체계운영기관은 다음 각 호에 해당하는 경우 담당 방첩부대에 평가를 의뢰하여야 한다. 다만, 체계 특성에 따라 인가권자 또는 상급 부대가 다수 부대를 통합하여 방첩사에 평가를 의뢰할 수 있다.

1. 인가 기간 만료일이 도래한 경우(만료일 6개월 전까지 의뢰)
2. 대상체계의 보안 수준에 상당한 영향을 미칠 수 있는 운영환경 변화가 있는 경우
3. 대상체계의 형상이 변경되어 보안통제항목에 영향을 미치는 경우

4. 운용 중 체계에 위험관리를 적용하는 경우

② 제1항에 따른 평가의 절차는 제30조를 준용하되 방사청의 역할은 체계운영기관에서 수행한다.

③ 체계운영기관은 평가 종료 후 보안평가결과서, 보안계획서, 후속조치 계획서를 인가권자에게 제출하여야 한다.

④ 인가권자는 제출된 문서를 검토하고 제32조를 준용하여 재인가를 수행하여야 한다.

⑤ 운용 중 체계에 위험관리를 적용하는 경우에는 보안평가 전까지 다음 각 호에 따라 위험관리 절차 1단계 시스템 보안분류와 2단계 보안통제항목 선정을 완료하여야 한다.

1. 1단계 시스템 보안분류: 소요제기기관은 대상체계에 포함된 정보유형을 식별하고 식별된 정보의 유형별 보안영향 수준을 판단해 별표 1의 기준에 따라 시스템 보안분류를 수행한다. 시스템 보안분류는 부대 보안심사위원회를 통해 결정한다.
2. 2단계 보안통제항목 선정: 체계운영기관은 시스템 보안분류 결과를 기초로 현재 운용 중인 체계에 적용된 보안대책을 반영하여 보안통제항목을 선정하고 보안계획서를 작성한다.

제36조(폐기) ① 체계운영기관은 폐기가 결정된 대상체계의 데이터 등이 유출되지 않도록 보안조치를 수행하고 담당 방첩부대에 보안조치 결과에 대한 검토를 의뢰하여야 한다.

② 담당 방첩부대는 제1항에 따른 보안조치 결과를 검토하기 위해 현장점검 등을 수행할 수 있으며 검토 결과는 체계운영기관에게 회신하여야 한다.

③ 체계운영기관은 제2항에 따른 검토 결과에 따라 후속조치 및 폐기 절차를 시행하고, 후속조치 결과를 포함한 대상체계 폐기 결과를 인가권자에게 보고하여야 한다.

④ 인가권자는 대상체계의 폐기 결과를 검토 후 최종 승인하고, 이를 국방부(지능정보화정책관)에 보고하여야 한다.

제5장 전력지원체계 위험관리

제1절 소요 단계

제37조(시스템 보안분류) ① 소요제기기관은 전력지원체계 소요를 제기하는 경우 대상체계에 포함된 정보유형을 식별하고 식별된 정보의 유형별 보안영향 수준을 판단해 별표 1의 기준에 따라 시스템 보안분류를 수행하여야 한다. 시스템 보안분류에 관하여 필요한 사항은 "시스템 보안 분류 가이드"를 참고한다.

② 소요제기기관은 부대 보안심사위원회를 통해 시스템 보안분류를 결정하며 필요한 경우 방첩사에 시스템 보안분류 결과를 포함한 소요제기서의 보안대책 항목에 대한 검토를 요청할 수 있다.

③ 방첩사는 제2항에 따른 시스템 보안분류 결과의 검토를 요청받은 경우 14일 이내에 해당 시스템 보안분류가 적절한지 여부를 판단해 회신하여야 한다.

④ 소요제기기관은 대상체계에 대한 인가권자를 결정하여 해당 내용을 제1항에 따라 수행한 시스템 보안분류의 결과와 함께 소요제기서에 기재하여야 한다.

⑤ 소요제기기관은 대상체계에 대한 모의침투 필요성을 검토하여 필요 여부를 소요제기서에 포함한다.

⑥ 소요제기기관은 제1항부터 제5항에 따른 시스템 보안분류 결과 등을 별지 제1호서식에 따른 시스템 보안분류 결과서에 기재하고 이를 소요제기서에 첨부하여 소요결정기관에 제출하여야 한다.

제38조(시스템 보안분류의 결정) ① 소요결정기관은 제37조에 따라 제출된 소요제기서를 검토하고 시스템 보안분류 결과, 모의침투 수행 여부, 인가권자 등을 소요결정에 반영하여야 한다.

② 소요결정기관은 제1항에 따른 소요결정 시 필요하다고 판단하는 경우 소요제기기관, 방첩사, 사이버사, 체계운영기관, 사업관리기관 등 관계기관의 의견을 들어 참고할 수 있다.

제2절 획득 단계

제39조(사이버보안조정회의) ① 사업관리기관은 전력지원체계 획득 단계에서 위험관리를 적용하는 경우 다음 각 호의 사항에 관한 의견을 조율하기 위해 사이버보안조정회의를 구성·운영할 수 있다.

1. 보안통제항목의 선정
2. 보안통제항목의 구현
3. 보안통제항목 책임기관의 지정
4. 보안평가 결과에 따른 후속조치 방안의 결정
5. 그 밖에 보안계획서 작성 및 보안통제항목 선정 등을 위해 의장이 필요하다고 인정하는 사항

② 사이버보안조정회의의 의장은 사업관리기관의 과장급으로 한다.

③ 사이버보안조정회의는 대상체계의 획득 및 평가, 운용과 관련된 각 기관의 담당자로 구성한다.

④ 의장은 사이버보안조정회의의 원활한 운영을 위해 필요하다고 판단하는 경우 기타 관계자의 참여를 요청할 수 있다.

제40조(보안통제항목 선정) ① 사업관리기관은 전력지원체계 개발을 위한 사업계획서 작성 단계에서 다음 각 호의 사항을 결정하고 이를 방첩사 및 사이버사에 회람하여야 한다.

1. 구현해야 할 보안통제항목의 선정 및 조정
2. 기술적, 관리적 보안통제항목 구현 책임기관 지정

② 사이버사는 대상체계에 대한 위협모델링 결과를 작성하여 방첩사 및 사업관리기관에 회람하여야 한다.

③ 방첩사는 제2항에 따른 위협모델링 결과를 참고하여 제1항에 따라 선정된 보안통제항목을 검토하고 그 결과를 20일 이내에 사업관리기관 및 소요제기기관에 회신하여야 한다.

④ 사업관리기관은 제3항에 따른 방첩사의 검토결과를 참고하여 보안통제항목을 조정하고 그 결과를 소요제기기관 및 방첩사에 통보한다.

⑤ 사업관리기관은 제4항에 따라 조정된 보안통제항목을 제안요청서(Request for Proposal, RFP)에 반영하여야 한다.

제41조(보안계획서 작성) ① 사업관리기관은 체계개발 단계에 보안계획서 작성에 대한 총괄 임무를 수행하여 보안계획서를 작성 및 종합하고 방첩사의 검토를 통해 보완하여 상세설계검토(Critical Design Review, CDR)에서 확정한다.

② 사업관리기관은 제40조제1항제2호에 따라 기술적으로 구현이 필요한 소관 보안통제항목에 대한 구현계획을 체계개발 사업 진행 과정에서 구체화하여 별지 제2호서식에 따른 보안계획서에 작성하여야 한다.

③ 소요제기기관은 제40조제1항제2호에 따라 관리적으로 구현이 필요한 소관 보안통제항목에 대한 구현계획을 구체화하여 별지 제2호서식에 따른 보안계획서에 작성하여야 한다.

④ 소요제기기관은 제3항에 따른 보안계획서 작성을 위하여 대상체계의 체계운영기관에 관련 자료 제출 등 협조를 요청할 수 있다.

⑤ 사업관리기관은 제2항 및 제3항에 따라 작성된 보안계획서를 종합하여 방첩사에 검토를 의뢰하여야 한다.

⑥ 방첩사는 제5항에 따른 보안계획서를 검토한 결과를 사업관리기관에 20일 이내에 회신하고 소요제기기관에 통보하여야 한다.

⑦ 사업관리기관은 제6항에 따른 방첩사의 검토 결과와 해당 사업의 성격을 고려하여 보안계획서를 보완하고 기술적 구현이 필요한 사항을 체계 설계 문서에 반영하여야 한다.

⑧ 사업관리기관은 제7항에 따라 보완이 완료된 보안계획서를 상세설계검토(CDR)에 반영하여 확정한다.

⑨ 사업관리기관은 구매사업 등 체계개발을 하지 않고 전력지원체계를 획득하는 경우에도 이 조의 절차를 준용하여 보안계획서를 작성하여야 한다.

제42조(보안통제항목 구현) ① 개발업체 및 체계운영기관은 제41조제8항을 통해 확정된 보안계획서에 따라 소관 보안통제항목을 구현하여야 한다.

② 사업관리기관은 제1항에 따른 보안통제항목 구현 과정에서 대상체계의 설계 변경 또는 기타 사유로 인해 보안통제항목을 구현하기 어려운 경우 사이버보안조정회의를 통해 해당 항목을 조정하고 그 결과 및 사유를 보안계획서에 반영하여야 한다.

③ 소요제기기관은 제1항에 따른 보안통제항목 구현 과정에서 관리적 보안통제항목을 구현하기 어려운 경우 사업관리기관에 사이버보안조정회의를 통한 조정을 요청할 수 있다.

제43조(전력지원체계 보안평가) ① 소요제기기관은 제42조에 따라 최신화된 보안계획서를 방첩사에 제출하고 보안평가를 의뢰하여야 한다.

② 방첩사는 제1항에 따른 의뢰를 받은 경우 30일 이내에 별지 제3호서식에 따른 보안평가 계획서(안)을 작성하여야 한다. 대상체계가 소요제기서상 모의침투 대상에 해당하는 경우에는 사이버사로부터 모의침투 계획을 제공받아 보안평가 계획서(안)에 반영하여야 한다.

③ 사업관리기관은 제2항에 따른 보안평가 계획서(안)을 검토하여 의견을 제시할 수 있다. 다만, 보안평가 계획서(안)에 이견이 있는 경우 사이버보안조정회의를 통해 보안평가 계획서(안)을 검토할 수 있다.

④ 방첩사는 제3항에 따른 검토결과를 참고하여 보안평가 계획서를 확정한다.

⑤ 방첩사는 보안평가 계획서에 따라 보안통제항목의 평가를 수행한다. 제2항에 따라 보안평가 계획서에 모의침투 계획이 포함된 경우 사이버사는 모의침투를 수행하여야 한다.

⑥ 방첩사는 제5항에 따른 보안통제항목 평가 결과를 바탕으로 보안평가결과서를 작성한다. 모의침투가 수행된 때에는 그 결과를 함께 반영하여야 한다.

⑦ 방첩사는 보안평가를 위해 필요한 경우 사업관리기관에 관련 자료의 구비 또는 제공을 요청할 수 있다.

⑧ 사업관리기관은 보안평가가 원활하게 수행될 수 있도록 개발업체의 통제 및 평가 여건 보장 등 필요한 사항을 지원하여야 한다.

제44조(보안평가 후속조치) ① 사업관리기관은 제43조에 따른 보안평가 결과 미흡한 보안통제항목이 있는 때에는 사이버보안조정회의를 통해 다음 각 호에 따라 해당 보안통제항목의 후속조치방안 및 조치수행기관을 결정하여야 한다.

1. 단기조치: 사업기간 내 조치가 가능한 경우
2. 중장기조치: 사업기간 내 조치가 불가능하여 사업 종료 이후 별도의 사업 또는 관리적 조치를 통해 조치가 필요한 경우

② 소요제기기관은 제1항에 따라 결정된 조치방안을 고려해 보안계획서에 반영하고 별지 제4호서식에 따른 후속조치 계획서를 작성하여야 한다.

③ 사업관리기관은 용역업체를 통해 사업기간 내 단기조치를 완료하고 그 결과를 반영해 보안계획서를 수정하여 방첩사에 제출하여야 한다.

④ 방첩사는 보안계획서와 단기조치 완료 여부를 확인하여 보안평가결과서에 반영하고 이를 소요제기기관에게 제출하여야 한다.

제45조(인가) ① 소요제기기관은 제44조에 따른 단기조치가 완료된 이후 보안계획서, 보안평가결과서, 후속조치 계획서를 종합하여 인가권자에게 운용인가를 건의한다.

② 인가권자는 보안계획서와 후속조치 계획서를 바탕으로 보안평가결과서에 따른 위험의 수용 여부를 판단하여 대상체계의 운용 여부를 다음 각 호에 따라 결정하고 별지 제5호서식에 따른 운용인가서를 발급하여야 한다.

1. 보안평가결과서에 따른 위험 단계가 '낮음' 또는 '매우 낮음'에 해당하는 경우: 인가
2. 보안평가결과서에 따른 위험 단계가 '보통'에 해당하는 경우: 인가 또는 조건부 인가
3. 보안평가결과서에 따른 위험 단계가 '높음' 또는 '매우 높음'인 경우: 조건부 인가

③ 보안평가결과서에 따른 위험이 '높음' 또는 '매우 높음'임에도 불구하고 자체 판단이 어려운 경우 인가권자는 제11조에 따른 실무위원회에 인가 여부의 판단을 요청할 수 있으며 실무위원회의 심의 결과에 따라 대상체계의 운용 여부를 최종 결정하여야 한다.

④ 인가권자는 운용 여부 결정 시 기간을 정할 필요가 있는 경우 별표 2에 따라 인가 기간을 정할 수 있다. 다만, 대상체계의 운용 여부가 '조건부 인가'인 경우 또는 타국 체계와 연동된 체계, 주요국방정보시스템의 운용 여부를 결정하는 때에는 반드시 인가 기간을 정해야 한다.

제3절 운용 단계

제46조(모니터링) ① 체계운영기관은 보안계획서에 따라 대상체계를 운영·관리하여야 하며, 인가권자는 이를 관리·감독하여야 한다.

② 체계운영기관은 제1항에 따른 대상체계 운영·관리 과정을 기록하여 관련 자료를 유지, 관리하고 제8조에 따른 K-RMF운영시스템에 등록하여야 한다.

③ 체계운영기관은 운영환경, 사이버 위협 등 주변 상황을 고려하여 보안계획서를 변경해야 하는 경우 보안계획서 변경안을 작성하고 담당 방첩부대에 검토를 의뢰하여야 한다.

④ 제3항에 따른 검토를 의뢰받은 담당 방첩부대는 보안계획서 변경안을 검토하여 그 결과를 체계운영기관에 회신하여야 한다.

⑤ 방첩사는 체계운영기관에서 보안계획서에 따라 대상체계를 관리하는지 여부를 확인·점검할 수 있다.

⑥ 방첩사는 제5항에 따른 대상체계 확인·점검 결과와「국방사이버안보 훈령」제46조에 의한 사이버보안 기관평가 결과 등을 통해 식별된 보안관리 수준, 체계 운영환경 및 사이버 위협 등 주변 변화를 고려해 필요하다고 판단하는 경우 대상체계에 대한 수시 보안평가를 실시할 수 있으며, 그 결과는 인가권자, 국방부(지능정보화정책관) 및 국방정보본부(정보기획부)에 제출하여야 한다.

⑦ 인가권자는 제6항에 따른 결과를 고려해 인가 여부를 재판단할 수 있다.

⑧ 체계운영기관은 제6항에 따른 수시 보안평가 결과 및 제7항에 따른 인가 여부의 재판단 결과를 반영해 보안계획서 또는 후속조치계획서를 최신화하여야 한다.

제47조(운영 중 평가 및 재인가) ① 체계운영기관은 다음 각 호에 해당하는 경우 담당 방첩부대에 평가를 의뢰하여야 한다. 다만, 체계 특성에 따라 인가권자 또는 상급 부대가 다수 부대를 통합하여 방첩사에 평가를 의뢰할 수 있다.

1. 인가 기간 만료일이 도래한 경우(만료일 6개월 전까지 의뢰)
2. 대상체계의 보안 수준에 상당한 영향을 미칠 수 있는 운영환경 변화가 있는 경우
3. 대상체계의 형상이 변경되어 보안통제항목에 영향을 미치는 경우
4. 운용 중 체계에 위험관리를 적용하는 경우

② 제1항에 따른 평가의 절차는 제43조를 준용하되 사업관리기관의 역할은 체계운영기관에서 수행한다.

③ 체계운영기관은 평가 종료 후 보안평가결과서, 보안계획서, 후속조치 계획서를 인가권자에게 제출하여야 한다.

④ 인가권자는 제출된 문서를 검토하고 제45조를 준용하여 재인가를 수행하여야 한다.

⑤ 운용 중 체계에 위험관리를 적용하는 경우에는 보안평가 전까지 다음 각 호에 따라 위험관리 절차 1단계 시스템 보안분류와 2단계 보안통제항목 선정을 완료하여야 한다.

1. 1단계 시스템 보안분류: 소요제기기관은 대상체계에 포함된 정보유형을 식별하고 식별된 정보의 유형별 보안영향 수준을 판단해 별표 1의 기준에 따라 시스템 보안분류를 수행한다. 시스템 보안분류는 부대 보안심사위원회를 통해 결정한다.

2. 2단계 보안통제항목 선정: 체계운영기관은 시스템 보안분류 결과를 기초로 현재 운용 중인 체계에 적용된 보안대책을 반영하여 보안통제항목을 선정하고 보안계획서를 작성한다.

제48조(폐기) ① 체계운영기관은 폐기가 결정된 대상체계의 데이터 등이 유출되지 않도록 보안조치를 수행하고 담당 방첩부대에 보안조치 결과에 대한 검토를 의뢰하여야 한다.

② 담당 방첩부대는 제1항에 따른 보안조치 결과를 검토하기 위해 현장점검 등을 수행할 수 있으며 검토 결과는 체계운영기관에게 회신하여야 한다.

③ 체계운영기관은 제2항에 따른 검토 결과에 따라 후속조치 및 폐기 절차를 수행하고, 후속조치 결과를 포함한 대상체계 폐기 결과를 인가권자에게 보고하여야 한다.

④ 인가권자는 대상체계의 폐기 결과를 검토 후 최종 승인하고, 이를 국방부(지능정보화정책관)에 보고하여야 한다.

제6장 보칙

제49조(적용 특례) ① 제4조제2항에도 불구하고, 대상체계에 대한 위험관리는 다음 각 호와 같이 적용한다.

1. 무기체계: 2024년 7월 1일 이후 장기에서 중기로 소요가 결정되거나 중기 신규로 소요제기되는 체계 중「국방전력발전업무훈령」에 따른 전장관리정보체계에 우선적용하며, 기타 분류는 우선적용 대상체계에 대한 K-RMF 적용결과를 검토하여 단계적으로 확대 적용한다.
2. 전력지원체계: 2026년 1월 1일 이후 사업에 착수하는 체계

② 국방부(지능정보화정책관)는 다음 각 호에 따른 특정 운용 중 대상체계에 위험관리를 적용하도록 할 수 있다.

1. 연합・합동지휘통제체계 및 외국군과 연동하는 체계(AKJCCS, KJCCS, JFOS-K, MIMS-C, KICC, TCPED)
2. 지상・해상・공중지휘통제(ATCIS, KNCCS, AFCCS)
3. 그 밖에 국방부(지능정보화정책관)가 사이버보안을 위해 필요하다고 판단하는 대상체계

③ 기존 운용 중인 대상체계에는 기존에 적용되는「국방보안업무훈령」및「국방사이버안보 훈령」에 따른 보안관리 절차를 그 대상체계의 폐기 또는 신규 사업을 통해 성능을 개량하기 전까지 적용한다. 다만, 기존 운용 중인 대상체계도 제8조에 따른 K-RMF 운영시스템에 등록하여 현황을 관리한다.

④ 무기체계 구매사업에 대한 적용은 제1항제1호에도 불구하고 2026년 이후로 유예하며, 방사청은 무기체계 구매사업에 대한 K-RMF 적용 여부, 대상 및 절차 등을 국방부와 협의하여 구체화하여야 한다.

⑤ 이 지시에 따라 보안계획서 검토 및 보안평가를 받은 경우에는「국방사이버안보 훈령」및「국방보안업무훈령」의 보안대책 검토와 보안측정을 받은 것으로 본다.

부칙 <제2024-15호,2024.4.12.>

제1조(시행일) 이 지시는 발령한 날부터 시행한다.

부칙 <제2025-8호,2025.2.28.>

이 훈령은 발령한 날부터 시행한다.

[별표 1] 시스템 보안분류 기준
[별표 2] 인가 등급별 기간
[별지 1] 시스템 보안분류 결과서
[별지 2] 보안계획서
[별지 3] 보안평가 계획서
[별지 4] 후속조치 계획서
[별지 5] 운용인가서
[별지 6] 보안평가 결과서
[별지 7] 보안통제항목 선정 결과

【별표 1】

시스템 보안분류 기준

구분	기밀성	무결성	가용성	비밀자료 처리
분류결과	상, 중, 하	상, 중, 하	상, 중, 하	O, X

【별표 2】

인가 등급별 기간

구 분	매우낮음	낮음	보통	높음	매우높음
인가 기준	5년 이하 인가	3년 이하 인가	2년 이하 인가 또는 조건부 인가	1년 이하 조건부 인가	1년 이하 조건부 인가

시스템 보안분류 결과서

(앞쪽)

1. 분류결과

가. 시스템 보안분류 결과 :

구분	기밀성			무결성			가용성		
분류결과	상	중	하	상	중	하	상	중	하

※ 비밀자료 처리 : [ ] 예 [ ] 아니오

나. 모의침투 수행 여부 : [ ] 수행 [ ] 미수행

다. 인가권자 :

2. 세부내용

가. 시스템 보안분류 : 기밀성( ), 무결성( ), 가용성( )

- 정량적 분류 : 기밀성( ), 무결성( ), 가용성( )
- 정성적 분류 조정(정보유형에 대한 보안영향수준 판단) : (조정 없음)
- 조정 결과 : 기밀성( ), 무결성( ), 가용성( )

나. 암호대책

구분	국가용 암호장비	KCMVP 암호모듈	기타
사용 여부	O, X	O, X	서술

다. 모의침투 수행 필요성

- 내용 서술

라. 보안통제항목 초기 선정 : 총 000개

- 기준선 : 보안통제항목(00개), 강화항목(000개), 총 000개

* 개발 중 구체화하며, 전력소요서 수정 없이 IPT 주관 사이버보안조정회의를 통해 변경 가능

붙임. 시스템 보안분류 양식

210㎜×297㎜[백상지(80g/㎡) 또는 중질지(80g/㎡)]

(뒤쪽)

붙임. 시스템 보안분류 양식

처리정보	국방정보유형			보안영향 기준선			보안영향수준 조정			조정 여부	조정 사유
	임무 영역	직무 기능	정보 유형	기밀성	무결성	가용성	기밀성	무결성	가용성		

210㎜×297㎜[백상지(80g/㎡) 또는 중질지(80g/㎡)]

보안계획서

1. 문서이력

가. 체계 사업 이력
나. 보안계획서 작성 이력
다. 붙임문서 이력

2. 일반계획

가. 일반 현황
나. 시스템 상세
다. 시스템 보안분류 결과
라. 추가 보안통제항목 선정 기준(오버레이)
마. 프로토콜, 포트, 서비스
바. 시스템 사용자 분류
사. 자산 관리
아. 외부 보안서비스
자. 담당자 및 연락처
차. 관련 법령 / 규정 / 지시 / 참고문헌

3. 보안통제항목 목록관리

가. 보안통제항목 선정 시 고려사항(가정사항)
나. 보안통제항목 선정

4. 보안통제항목 구현계획

5. 자산현황

6. 아키텍처

가. 시스템 구성도
나. 시스템 설명

7. 기타

붙임: 암호기술, 외부시스템 간 정보흐름, 연동근거 등

보안평가 계획서

1. 시스템 개요

가. 일반현황(시스템명, 수명주기, 비밀 종류 및 등급)

나. 시스템 분류결과

다. 선정된 보안통제항목

2. 평가현황

가. 평가범위

나. 주요 자산현황(하드웨어, 소프트웨어)

3. 평가계획

가. 평가기간

나. 평가팀 편성

다. 평가 중점

라. 시스템 관계자

4. 참고사항

가. 전제조건

나. 책임한계

붙임. 보안통제항목별 평가방법

후속조치 계획서

1. 일반현황

가. 시스템명 :

나. 인가기관 :

다. 운영기관 :

라. 최초 작성일 :

마. 최종 수정일 :

2. 책임/담당자 현황

구 분	직책	성명	연락처
책임관			
담당자			

3. 후속조치 현황

보안통제항목	평가결과	구현여부	담당자	조치 내용	조치 구분	조치 상태

운용인가서

1. 시스템 개요

가. 시스템명 :

나. 운영부서 :

다. 평가일자 :

2. 세부 평가결과

가. 평가기간 :

나. 평가관 구성 :

다. 평가결과 : 보통

라. 평가결과 요약

3. 인가현황

가. 인가부서 :

나. 인가권자 :

다. 인가여부 :

라. 인가기간 :

마. 만료일자 :

보안평가 결과서

1. 일반현황

가. 시스템 개요

나. 시스템 보안목표

다. 보안통제항목

라. 평가일정

바. 평가범위

마. 평가팀 편성

2. 보안통제항목 평가결과

가. 평가결과

나. 평가결과 분석

3. 위험판단 결과

가. 위험판단 대상

나. 시스템 위험도

다. 위험 완화를 위한 권고조치

4. 모의침투 결과

가. 모의침투 중점

나. 식별된 취약요인

다. 조치 우선순위

5. 권고사항

보안통제항목 선정 결과

1. 일반현황

가. 인가권자 :

나. 시스템 보안분류 결과 :

구분	기밀성	무결성	가용성
분류결과			

※ 비밀자료 처리 : [ ] 예 [ ] 아니오

다. 보안통제항목 선정결과 : 000개(기본통제항목 000개, 강화통제항목 000개)

구분	기준선	오버레이	시스템 특성
계	000	000	000
기본보안통제항목	000	000	000
강화보안통제항목	000	000	000

2. 보안통제항목 세부선정결과

항목 번호	항목명	기준선	오버레이	시스템특성	조정사유
AC-1	접근통제	O	비밀처리	-	
AC-3-7		X	X	O	필요